

A Situation Awareness Model for Information Security Risk Management

Jeb Webb

Atif Ahmad

Sean B. Maynard*

Graeme Shanks

Department of Computing and Information Systems

Melbourne School of Engineering

University of Melbourne

Victoria, Australia

*Corresponding Author Details

Email: sean.maynard@unimelb.edu.au

Phone: +61 3 8344 1573

Abstract

Information Security Risk Management (ISRM) is the primary means by which organizations preserve the confidentiality, integrity and availability of information resources. A review of ISRM literature identified deficiencies in the practice of information security risk assessment that inevitably lead to poor decision-making and inadequate or inappropriate security strategies. In this conceptual paper, we propose a situation aware ISRM (SA-ISRM) process model to complement the information security risk management process. Our argument is that the model addresses the aforementioned deficiencies through an enterprise-wide collection, analysis and reporting of risk-related information. The SA-ISRM model is adapted from Endsley's situation awareness model and has been refined using our findings from a case study of the US national security intelligence enterprise.

Keywords

Information Security Management; Information Security Risk Management; Information Security Intelligence; Information Security Compliance; Information Security Investigation; Evidence-Based Information Security; Situation Awareness; Situation Awareness Theory

1. INTRODUCTION

The protection of information resources from the complex and rapidly evolving security threat landscape is a significant challenge to the modern organization. Key concerns for organizations are the leakage and modification of sensitive information, such as intellectual property and trade secrets, and the disruption or destruction of mission-critical IT services, such as those employed by e-commerce providers. The trend towards social networking, BYOD and cloud computing technologies presents new avenues for information leakage, which can in turn result in significant damage to reputation, revenue and even competitive advantage.

Information security 'best-practice' standards such as the ISO27000 series suggest a range of managerial and technical controls to protect information resources. However, the standards acknowledge that the level of security risk exposure must guide an organization's selection of controls. Therefore, organizations are advised to adopt a risk management approach to information security.

The objectives of information security risk management (ISRM) are to (1) identify security risks (*risk identification*), (2) prioritize them according to severity (*risk assessment*), (3) determine the most cost-effective means of controlling security risk (e.g. avoidance, mitigation, transfer or risk) (*risk treatment*) and (4) monitor changes to the risk management system (*risk review*). The ISRM process hinges on an accurate assessment of the overall information security risk situation, i.e. the risk assessment phase, which involves the collection of a considerable amount of information about the organization's information resources (e.g. a complete and accurate list of discrete information assets, vulnerabilities to each asset, mappings of each threat-asset-vulnerability combination, and a determination of the likelihood and potential impact of each risk scenario). Undertaking a risk assessment is an expensive exercise, given the very large number of information assets in most organizations; the complex and evolving nature of security risk; and the difficulty in accurately determining likelihood or impact. Therefore, an obvious question would be "how effective is the practice of risk assessment in organizations, given typical information security budget limitations?"

Our review of the ISRM literature (see Section 2 for the review) did not identify any studies that made generalized claims about the effectiveness of the practice of risk assessment. Compared to the

literature on ISRM theory, method and concepts, there is very little literature on ISRM implementation and practice in organizations. There are possibly two reasons for this. First, organizations are reluctant to discuss information security practice, given the sensitive nature of the topic (Kotulic & Clark, 2004). Second, research assessing the effectiveness of practice requires investigators with in-depth knowledge of both risk management and information systems.

However, there have been a number of in-depth case studies into organizational information security practice, and considerable scholarly criticism, that suggest there are three endemic deficiencies in the practice of information security risk assessment (see sections 2.1-2.4 for justification): (1) Information security risk identification is commonly perfunctory; (2) Information security risks are commonly estimated with little reference to the organization's actual situation; and (3) Information security risk assessment is commonly performed on an intermittent, non-historical basis.

We believe that the critical issue for organizations is the need for situation awareness among information security managers. Situation awareness (SA) has been defined in theory as “*the perception of the elements in the environment within a volume of time and space, the comprehension of their meaning, and the projection of their status in the near future*” (Endsley 1988, in Endsley and Jones 2011, 13).

The decisions information security managers need to make relating to their organizations' information security postures (e.g. whether to change security practices to avoid negative situations that could cost the organization money, damage its reputation, or otherwise impede its accomplishment of strategic objectives) need to be informed by an accurate understanding of the risks their organizations are actually faced with. We observe that all three of the tendencies outlined above describe SA problems because they describe ways in which information pertaining to the organization's information security risk environment goes unperceived or un-comprehended (thereby precluding projection and, ultimately, informed decision-making and action).

Thus, we pose the following research question: *How can situation awareness be improved in information security risk management?*

In this paper we propose a situation aware ISRM process model to support ISRM practice. Our argument is that given the deficiencies reported in the literature, the risk assessment process in particular requires a comprehensive information collection, analysis and reporting mechanism to support the decision-making process. Although it is obvious that ISRM methods require comprehensive information collection to enable an accurate and comprehensive information security risk assessment, the collection of information is treated informally and is implicit to the process. The aforementioned deficiencies justify the need for a formal process of information collection where the relevant omissions do not occur, subsequently leading to improved situation awareness.

This paper is structured as follows. Section 2 introduces information security risk management (ISRM). A review of the ISRM literature highlights three key deficiencies that point to the lack of situation awareness and the need to address our research question. Section 3 introduces situation awareness (SA), provides an overview of previous SA-related research, including in information systems, identifies models of SA and presents Endsley's theory of SA, which is the basis for our own model. Section 4 introduces the intelligence cycle, the heuristic framework we used to organize findings from our case study of the US national security intelligence enterprise (USNSIE). Our research method is described in Section 5 and findings from our case study of the USNSIE are

presented in Section 6. Section 7 offers acknowledgment of practical and theoretical challenges for the project and presents our plan for future work.

2. LITERATURE REVIEW: INFORMATION SECURITY RISK MANAGEMENT

In principle, Information Security Risk Management (ISRM) processes allow organizations to determine whether they are protecting their information assets using the most effective and cost-efficient means. Fundamentally, risk is the “effect of uncertainty on objectives;” risk in the context of information security is “associated with the potential that threats will exploit vulnerabilities of an information asset or group of information assets and thereby cause harm to an organization” (AS/NZS ISO/IEC 27005:2011). The core activity of ISRM is risk assessment, which is a staged process that begins with the identification of risks, followed by their prioritized ranking, determining appropriate control strategies and finally monitoring their status (Whitman & Mattord, 2004). The highest priority concerns in ISRM are protecting the most critical information assets from compromise in the most high-risk scenarios as well as balancing cost of control against the level of security provided and the accessibility of information resources to end-users (Shedden, Ruighaver & Ahmad 2010).

Three endemic deficiencies have been highlighted in the literature on ISRM:

2.1. Deficiency 1: Information security risk identification is commonly perfunctory

There is considerable evidence that significant sources of risk are not being taken into consideration during the risk management process (Parker 2007; Utin, Utin & Utin 2008; Shedden et al. 2010; Shedden et al. 2011).

Examples of such omissions include:

1. Failures to identify risks related to intangible knowledge assets (e.g. distributed tacit knowledge) (Shedden et al. 2011);
2. Failures to identify vulnerabilities arising out of complex relationships between multiple information assets (Parker 2007; Utin et al. 2008);
3. Failures to identify emerging indications of malicious threats such as fraud, espionage, or sabotage (Kowalski, Cappelli and Moore 2008; Colwill 2009; Stewart and Lacey 2012);
4. Failures to systematically and continuously learn from past information security incidents for the benefit of information security risk assessment (Ahmad, Hadgkiss, & Ruighaver 2012); and
5. Failures to identify attack patterns, or to model complex or persistent attack scenarios in order to develop countermeasures/counterstrategies against them (Parker 2007; Raiu 2012).

There are many reasons why such omissions occur. For example, Shedden et al. (2010) point out that information security risk assessments are frequently conducted by professionals without backgrounds in *both* information systems and risk management. Also, while risk assessors have a need to know the roles of assets intimately, those with the most operational knowledge about information assets typically do not have an equal responsibility to provide this information (Shedden et al. 2011). Furthermore, when personnel with information pertinent to risk assessment do not share it, those responsible for information security risk management are left “out of the loop” (Ahmad et al. 2012).

However, Siponen (2006) points to the more fundamental problem of motivation. He argues that standards compliance only requires that risk management processes exist; it does not regulate the granularity of the processes themselves. Siponen’s conclusions are reinforced by the findings of Shedden et al. (2010). Shedden et al. (2010) conducted a series of three in-depth case-studies of

organizations claiming to comply with best-practice information security standards. They found all three organizations had forgone the more complex task of performing a granular assessment true to the intentions of the standards' designers. Instead, motivated by the need to comply with standards, they used a 'simplified' process of identifying and estimating risks, which used generalized threats and assets rather than specific risks. These so-called 'simplifications' allowed the organizations to collect a much smaller set of risk-related information than would have been necessary for a comprehensive risk assessment (albeit at the cost of actual security).

Matwyshyn (2009) also found evidence of organizations treating compliance as an end in its own right, citing two common arguments invoked by companies rationalizing away any need to increase their information security expenditures: a) compliance with legal requirements is assurance enough and b) security measures beyond these requirements represent needless spending. In the cases from which Matwyshyn (2009) derived her findings, information security risk management did not, from the perspective of the organizations studied, translate to more than formal compliance.

2.2. Deficiency 2: Information security risks are commonly estimated with little reference to the organization's actual situation

The development of appropriate control strategies is contingent upon accurate risk assessment. Assessment must be, to the greatest extent practicable, based on evidence rather than speculation.

In a seminal article on the topic of ISRM, Baskerville (1991) asserts that risk assessments are often not based on evidence: "Its basic data values (risk probabilities and loss estimates) are highly interpretive—often gleaned whole by the professional from an unstructured study of the complex multivariate organizational landscape." In other words, Baskerville found that for many practitioners risk analysis was not the systematic investigative process it should be. Other authors echo Baskerville's perspective, suggesting that the tendency to estimate risk without sufficient evidence endures to the present.

Parker (2007) criticizes both quantitative and qualitative approaches to risk assessment as being overly simplistic:

"...risks and vulnerabilities cannot be paired in simple ways. There are too many interrelated unknown and known variables, with unknown values. They all change in unknown ways over time, depending on unknown future circumstances such as system and business changes, labor disputes, social and political changes, unknown enemies' failures and successes, and enemy and defender frailties and irrationalities." (Parker 2007, 120)

Parker points out that through systematic investigation and monitoring, many of the unknown and unpredictable variables can be rendered known and predictable—with the end result being more accurate risk assessments.

Utin et al. (2008) shared Parker's view that quantifying information security risk is conventionally impossible: "There are too many variables to consider, including users, computer environments, and business environment. If there are no reliable statistics, there can be no statistical simulation and therefore no 'measured or measurable risk.'" Essentially, Utin et al. (2008) argue that collecting relevant statistical data is impracticable. While it will never be possible to gather enough data to predict all future events with certainty, it does stand to reason that the collection of more data—if paced with the ability to process it—will yield a better understanding of risk.

2.3. Deficiency 3: Information security risk assessment is commonly performed on an intermittent, non-historical basis

Many organizations conduct information security risk assessments as infrequent events (Rees and Allen 2008). Rees and Allen (2008) found that the majority of respondents in their study felt information security risk assessments need only be conducted annually (31%) or quarterly (24%) and 14% of respondents believed that risk assessments need to be conducted less than once a year or “only as needed.” An infrequent performance of risk assessment compounds the factors mentioned under Deficiency 2, making a detailed assessment particularly overwhelming because all information must be gathered at once over a short period.

More importantly, information gathered at any one point in time can only constitute a status “snapshot” of the organization’s fluid information security environment (Schmittling 2010). Ensuring that an organization’s information-dependent processes function securely, and on a continuous basis, requires understanding the relevant variables and how changes within the environment can affect them. Hulme (2004) notes that “a risk assessment conducted on the first day of the month can be quite different than the same assessment conducted several weeks later.” He goes on to explain that organizations must stay “eternally vigilant” by constantly repeating a four phase cycle: “(1) identify new assets, vulnerabilities, and threats; (2) assess and classify assets, vulnerabilities, and threats; (3) remediate and defend; and (4) return to Step 1” (Hulme 2004). Ahmad et al. (2012) argue that it is also important for organizations to retain memory of past information security incidents and recognized indications of problems. In their failure to remain “eternally vigilant,” many organizations are missing vital, risk-pertinent data embedded within current developments and long-term trends—data that might otherwise afford them advance warning of impending incidents (if incorporated into predictive analyses).

Each of the three flaws outlined above describes a way that important information security risk intelligence is misapprehended or simply missed altogether. Without good intelligence, information security managers cannot make informed decisions. Appropriate defense postures cannot be taken because the risks at hand remain unclear. We argue that this problem can be described as one of deficient *situation awareness* in ISRM.

3. SITUATION AWARENESS (SA)

“SA is being aware of what is happening around you and understanding what that information means to you now and in the future. This awareness is usually defined in terms of what information is important for a particular job or goal. The concept of SA is usually applied to operational situations, where people must have SA for a specific reason, for example, in order to drive a car, treat a patient, or separate traffic as an air traffic controller” (Endsley and Jones 2011, 13).

SA has been studied in regard to a variety of operator types, including air traffic controllers (e.g. Endsley et al. 2000b); anesthesiologists (e.g. Fioratou et al. 2010); pilots (e.g. Endsley 1990); drivers (e.g. Bolstad 2001); emergency responders (e.g. Groner, Jennings, & Robinson 2012); ship crews (e.g. Chauvin et al. 2013); power plant operators (e.g. Hogg, Torralba & Volden 1993); train drivers (e.g. Naweed, Hockey & Clarke 2013); teleoperators (e.g. Riley, Kaber & Draper 2004); and soldiers (e.g. Endsley et al. 2000a).

3.1 SA in Information Systems Literature

In information systems, most SA-related research has concerned user interface design toward individual SA-support, e.g. for doctors (e.g. Morineau et al. 2009), nurses (e.g. Koch et al. 2012), and other hospital staff (e.g. Pennathur et al. 2011); pilots (e.g. Schnell et al. 2004); drivers (e.g. Harvey et al. 2011); and ship navigators (e.g. Sauer et al. 2002), or SA-supportive collaborative platforms, e.g. in science (e.g. Sonnenwald, Maglaughlin, and Whitton 2004); software development (e.g. Espinosa et al. 2007); crisis management (e.g. Gryszkiewicz and Chen 2012); emergency management (e.g. Senior and Copley 2008); emergency response (e.g. Yang, Guofeng and Hongyong 2012); disaster monitoring (e.g. Rogstadius et al. 2013); epidemic monitoring (e.g. DeFraites and Chambers 2007); and planned event management (e.g. Ng and Kankanhalli 2012). Other SA research in information systems has studied the SA of video game players (e.g. Reid et al. 2010); internet users (privacy) (e.g. Sim, Liginlal and Khansa 2012); information control in counterterrorism (counter-SA) (e.g. Oh, Agrawal, and Rao 2011); and simulated SA in automated systems such as malware detection (e.g. Dube et al. 2013) and surveillance systems (e.g. Abidi et al. 2008).

A search of scholarly articles yielded two results for work involving SA and information security. Shaw et al. (2009) conducted a laboratory experiment in which subjects were found to learn more from information security awareness training presentations that consisted of higher information content than from information security awareness training presentations that consisted of lower information content. Dinev and Hu (2007) found that survey respondents who believed in the necessity of anti-spyware technology were more likely to use it. They further found that respondents who understood a particular positive technology were more likely to use that technology, whereas respondents who understood a particular negative technology were more likely to avoid that technology (Dinev and Hu 2007). As neither of these papers directly concerns the SA of ISRM practitioners (i.e. in their management practices), neither is directly relevant to our research problem. We were unable to find any literature that concerned SA in ISRM.

3.2 Theoretical models of SA

SA models can be prescriptive or descriptive. Prescriptive models, typically developed in the aviation domain, tend to be very complex, as they concern detailed mappings between specific cognitive processes and precise operator tasks, all of which occurs in the context of one particular operational scenario (Rousseau, Tremblay and Breton 2004, 11). Given these characteristics, prescriptive models do not lend themselves well to the current project, which first concerns itself with developing a holistic/general solution (i.e. in the form of a standard process) for SA deficiencies in ISRM.

The majority of SA models are descriptive models, which aim to describe the SA phenomenon itself, and can be applied with relative ease to different contexts (Rousseau et al. 2004, 7). Commonly cited descriptive models of SA include Smith and Hancock's (1995), Bedny and Meister's (1999), and Endsley's (1995). Of these models, the linear presentation of SA maturity in Endsley's model lends itself most easily to adaptation for organizational process design. It essentially presents SA development as a chain of activities and outputs that occur in the context of decision-making and action, providing a readymade template for SA assurance. As we are interested in developing a process that can be used by organizations to assure SA in ISRM decision-making, we have chosen Endsley's model in our research.

3.3. Endsley's Theory of SA

Endsley's model depicts how SA is achieved in progressive stages (see Figure 1). In Level 1 SA, one perceives, or becomes aware of, "the status, attributes, and dynamics of relevant elements in the

environment” (Endsley 1988, in Endsley and Jones 2011, 16). Failure to achieve Level 1 SA essentially amounts to a failure to perceive relevant information about the environment (or “situation”), given one’s information requirements in light of one’s goals and objectives.

In Level 2 SA, one compares perceptions of the situation against one’s internally held understanding of, or associations regarding, this incoming information (“prototypical situations in memory;” Endsley 1995). Failure to achieve Level 2 SA amounts to a failure to understand what has been perceived, which can stem from information overload or from having inadequate informational templates (e.g. “mental models” held in human memory) to reference while processing and interpreting the sensed/incoming information (Endsley 1995). When Level 2 SA is achieved, one is aware of the incoming information’s intrinsic meaning(s), as well as its significance in the context of functional goals and objectives.

Level 3 SA occurs when one is able to extrapolate the implications of things perceived within the environment; to predict what will happen “at least in the very near term,” based on one’s understanding of cause and effect relationships between the elements of a situation (Endsley 1995). To achieve Level 3 SA, one must already have developed Level 2 SA. Level 3 SA enables one to anticipate and plan for alternative future scenarios. Failure at this level can stem from information overload or inadequate subject matter knowledge (Endsley and Jones 2011, 18). Endsley’s model portrays SA as a phenomenon that occurs in the context of decision-making, as it recognizes SA to be purposeful or goal oriented: “Goals form the basis for most decision-making in dynamic environments” (Endsley 1995). What we might call “high fidelity” Level 3 SA, or Level 3 SA borne out of assessing the situation of interest accurately and then interpreting it rationally in the context of goals and objectives, becomes the basis for informed decision-making (Endsley and Jones 2011, 13-14, 15, 18).

At the top and bottom of the diagram are task/system and individual factors that bear on the SA development and decision-making processes. All of these factors only become meaningful in the context of a specific individual or system. However, as we are also concerned with coordinated or “team” SA development, the roles of “goals and objectives”—which are shared between team members—have special relevance and were therefore singled out for representation in our adapted model. Endsley (1995) explains that SA within a team involves “a specific set of SA elements” for each member, pertinent to his or her functions within the team, with some overlapping between these elements. Overlapping occurs where goals and objectives are shared between team members. Similarly, any member may acquire information that meets the SA needs/requirements of another member and, in such a case, this information should be shared (Endsley 1995). Endsley (1995) defines the SA of the team as “the degree to which every team member possesses the SA required for his or her responsibilities”.

3.3. Towards an exemplary model of situation awareness for ISRM

Although Endsley’s model has been repeatedly validated, it has not been applied before to ISRM. Thus, while Endsley’s model tells us how SA is developed, it does not provide a ready-made answer to our research question. Lacking a best practice model nominally associated with SA support in ISRM, we looked for a model demonstrating SA support in some other security management context. As it is commonly recommended that information security risk management in general, and risk assessment in particular, should be carried out by a team consisting of individuals from across the organization (e.g. Harris 2010, 75, 77), we were especially interested in a model that described how a

team could support the SA of an individual decision-maker in an information security management context.

We determined that the US National Security Intelligence Enterprise (USNSIE) (i.e. the relationship between the US Intelligence Community and the military and governmental decision-makers that the Intelligence Community serves) could provide us with such a model. However, a search of literature on the USNSIE revealed that no single theory has been accepted as the definitive “theory of intelligence” one might use to model this enterprise (Treverton et al. 2006). Thus, while we had a robust theory of SA and an exemplary case (the USNSIE) in which a team (the US IC) supports the SA of individual decision-makers in a security management context, we did not have a robust theoretical model of this enterprise that we could then adapt for use in ISRM. To get such a model we had to create it ourselves. To do this we investigated whether it might be possible to model the USNSIE using the tenets of Endsley’s SA theory. To do this we conducted a case study of the US Intelligence Community (US IC).

4. THE INTELLIGENCE CYCLE

For a high level explanation of what the USNSIE does, we looked to the heuristic framework known as the “intelligence cycle,” which is typically used to describe how the US IC identifies the intelligence needs of decision-makers (“consumers”) and carries out operations to meet these needs (Johnson 2012, 37). We referred to this intelligence cycle framework when comparing the workings of the USNSIE against Endsley’s theoretical model. Our goal was to demonstrate that Endsley’s theoretical model of SA could be adapted to yield a better description of what actually happens within the USNSIE. This improved process description could then be used to guide design of an intelligence-driven ISRM method.

The number of discrete phases composing the intelligence cycle is a matter of opinion and varies across authors. The classic form of the intelligence cycle consists of five phases: planning and direction, collection, processing, analysis, production, and dissemination (Johnson 2012, 37). Lowenthal (2000, 40) contends that this representation of the cycle omits two phases integral to its looped nature, however, as the planning and direction phase is actually preceded by the issuance of requirements, and the dissemination phase is succeeded by consumption and feedback from the consumer.

Lowenthal’s (2000, 40) explanation thus yields a seven phase cycle: “identifying requirements; collection; processing and exploitation; analysis and production; dissemination; consumption; and feedback”. As Lowenthal’s cycle omits the planning and direction phase offered in the five phase model (which can itself be broken into two phases), and consolidates processing and exploitation into one phase, and analysis and production into another, a more granular representation of the cycle comprising these activities would consist of eleven phases: requirements, planning, direction, collection, processing, exploitation, analysis, production, dissemination, consumption, and feedback.

It can be argued however that not even an eleven-phase representation of the cycle is complete because it portrays intelligence production leading directly to dissemination, whereas the final product must actually be evaluated prior to dissemination. This is evinced in the examination and approval of National Intelligence Council National Intelligence Estimates by the National Intelligence Board prior to their dissemination to the National Security Council (Bruno and Otterman 2008, under “The NIE Writing Process”). Given the above argument, we present the intelligence cycle as a twelve phase

cycle in which an evaluation phase occurs between the production and dissemination phases. A representation of this cycle is presented in Figure 2.

Phase 1, **requirements**, refers to the information needs that must be met. During phase 2, **planning**, leaders and decision makers within the intelligence community determine how they will go about getting the requested information. In phase 3, **direction**, everyone involved in the effort to provide this information is given instructions on what to do. In phase 4, **collection**, information on the situation of interest is collected, by human or technical means, to yield "raw intelligence." In phase 5, **processing**, the raw intelligence is then processed to yield coherent information describing the states of elements in the situation. Phase 6, **exploitation**, describes the organization and sorting of the processed information in a way that is conducive to analysis by a human analyst. **Analysis** (phase 7) is the examination and consideration of situational elements in the overall context of the situation, and in light of the goals and objectives of the Intelligence Community and governmental decision makers.

While analysis describes the process of deriving answers based on the available information, phase 8, **production**, concerns the structuring of these answers for communication. An intelligence product is a formal answer to explicit and implicit questions posed by a consumer. Phase 9, **evaluation**, describes the process of checking the product to ensure that it does in fact answer the question(s) posed by the consumer (as the Intelligence Community exists to meet consumer needs, this phase is particularly important). **Dissemination**, phase 10, describes the communication of finished intelligence and phase 11, **consumption**, refers to the consumer's receipt of that intelligence. In phase 12, **feedback**, the consumer confirms that his or her intelligence needs have been met, explains that these needs have not been met, or issues new intelligence requirements based on his or her changed/changing needs.

In the section that follows, we will explain how we adapted Endsley's theoretical model of SA to describe the basic functionality of the USNSIE in the form of a process model. This process model in turn provides our template for a situation-aware ISRM process.

5. RESEARCH METHOD

We conducted a single case study of the US IC using publically available documents. Our rationale for drawing findings from one case study is that the US national security intelligence enterprise is a "unique" and "revelatory" case (Yin 2009, 23, 48-49). It is a case that affords us insight into how a "best practice" *organizational SA-support system* operates, including the key actors and functions involved at its strategic mission level and how these actors and functions are centrally managed. We used the open, axial and selective coding methodology as specified by Neuman (2011, p511) to analyze the documents. We analyzed 71 publically available documents that included US laws, Intelligence Community policy documents (Intelligence Community Directives), military manuals, US Government publications, US Government websites, and authoritative works produced by subject matter experts.

Initially, open coding was carried out on 32 Intelligence Community Directives and 5 pieces of US legislation to compile a lexical concordance of named actors and functions (Carley 1993). This produced a table containing 154 entries (171 pages) that documented roles within the intelligence community. Subsequently, two rounds of axial and selective coding were conducted to:

- Generate a process description explaining which actors performed which functions in the intelligence community (round 1).

- Identify where efforts were concentrated at the highest intelligence community management (ODNI) level, in order to extrapolate from this the key drivers of the enterprise (round 2).

During the first round of axial coding, we assembled a detailed process description of USNSIE workings. We first developed an outline of the intelligence cycle in which each phase represented the heading of a section. Next, we constructed a step-by-step account of what happens within the USNSIE throughout the intelligence cycle. As we drafted this account, we focused on the main actors and functions involved. We then used several repetitions of selective coding to refine the description of actors and functions involved in the intelligence cycle, producing a simple but accurate process description in prose.

As the US IC as a whole can be conceived as a unitary actor, the relationship between the US IC and any decision maker in government can be represented as a relationship between two actors. With this in mind, we adapted Endsley's theoretical model of SA to produce a process model describing the USNSIE as an SA-support enterprise (see Figure 3). The top half of the figure represents the US IC and the bottom half represents the supported decision maker.

We then verified the adapted model by comparing concepts from SA theory (i.e. task and system factors ("unknown" where applicable), stages of SA development, decision and action phases, and its feedback loop) to the phases of the intelligence cycle to identify points of analogy. This was accomplished through the pattern matching variation of the illustrative method (Neuman 2011, 519-20). This involved filling the structural components of Endsley's theoretical model with case study data. Evidence from the case study was reconsidered within the context of Endsley's SA-development/ decision/ action cycle and matched against our initial adaptation of Endsley's theoretical model (Figure 3) and the intelligence cycle to produce a refined model (Figure 4; see section 6).

During the second round of axial coding we focused on ODNI positions to determine how IC management functions were distributed. From our analysis of the case documents we identified that throughout the history of the ODNI, eight different Deputy Directors of National Intelligence (secondary assistants to the DNI) are mentioned, in acquisition and technology; intelligence collection; intelligence analysis; intelligence integration; "requirements" (later "policy, plans and requirements"); management; and customer outcomes related roles.

During the selective coding phase we focused on identifying personnel/resource distributions at the Assistant Deputy Director of National Intelligence (DDNI assistant) level. The reason for doing this was to identify where, historically, most of the ODNI's management effort has been concentrated. Of the nineteen named Assistant Deputy Directors of National Intelligence we identified in axial coding, the majority (eleven) were assistants to either the DDNI/Collection or the DDNI/Analysis (both of which appear to have since been re-classed beneath the DDNI/Intelligence Integration). From these findings, it is evident that management of the US IC predominantly involves the integration of collection and analysis activities, which is to say that effective management of the intelligence enterprise is mostly a matter of managing the personnel who perform these two core activities, and of ensuring that their efforts are coordinated. We then revised the model to indicate that responsibility for most US IC activities essentially falls on these two types of actors (See Figure 4).

6. FINDINGS

In this section, the findings from our case study are presented in the form of a USNSIE process model (see Figure 4 and the written description that follows). The USNSIE process model is a stripped down

representation of what happens in the USNSIE; as such, it represents some of the more general findings from our case study, which are used here to lay our foundations for future research. We plan to reference some of our more specific findings in future work toward the development of a comprehensive situation aware ISRM method. Figure 4 maps the phases of the intelligence cycle to our model and denotes the US IC's two key or "driver" actor types: collectors and analysts (color-coded light blue and dark blue, respectively). The purpose for this is twofold. First, it demonstrates that the USNSIE can in fact be described as an SA-support enterprise that adheres to the tenets of Endsley's SA theory. Second, it demonstrates that analogies can be drawn from the USNSIE exemplar to answer our research question.

In the written description that follows, points of analogy between intelligence cycle activities and the structural components of our process model are briefly described. The description of USNSIE activities has been minimized in the interest of space; as this paper concerns only the high level model depicted in Figure 4, most of the details pertaining to particular actors and functions within the USNSIE would be redundant to mention at this stage. The implications of these findings for an ISRM-specific model follow in the discussion section.

6.1. Intelligence cycle phases 1, 2, and 3 (*Requirements, Planning, and Direction*) are analogous to the *Goals and Objectives* individual factors component of SA theory.

The goals and objectives of decision-makers (e.g. the President of the USA) determine intelligence requirements. These requirements are then translated into operational requirements at the Intelligence Community element level (intelligence organizations e.g. CIA, DIA) (ICD 900, 2006; JP 2-0, 2007). In phases 2 and 3, planning and direction by Intelligence Community leadership (e.g. National Intelligence Managers, the heads of intelligence organizations and heads of divisions within those organizations) determines the goals and objectives of operators within Intelligence Community elements (ODNI 2011). These goals and objectives provide the context by which situational element states are judged—determining what needs to be perceived and why, and informing understanding of developments' implications, given the goals and objectives of the decision-making intelligence consumer (ODNI 2011).

6.2. Intelligence cycle phases 4, 5, and 6 (*Collection, Processing, and Exploitation*) are analogous to the Level 1 SA (*Perception*) component of SA theory.

During collection, situational element state data is gathered by human or technical assets (e.g. human spies or satellites) (Johnson 2012, 44; JP 2-0, 2007). Perception occurs when element states are perceptible by conscious agents (Endsley 1995). In human assets, collection and processing can occur concurrently; human perception of technical data occurs after some machine processing (JP 2-0, 2007; Miller 2004). Exploitation requires basic relevance recognition and is often automated to some extent (e.g. the recognition and labeling of data forms such as the shapes of military equipment objects in satellite images) (JP 2-0, 2007; ICD 300, 2006; ODNI 2011). Humans facilitate exploitation by labeling and classifying information for easy discovery or by forwarding information where useful, e.g. filing raw or processed intelligence into fusion centered databases, or forwarding it to appropriate analysts or other requesting consumers (Miller 2004; ODNI 2011).

6.3. Intelligence cycle phase 7 (*Analysis*) is analogous to the Level 2 SA (*Comprehension*), Level 3 SA (*Projection*) and *Decision* components of SA theory.

Situation comprehension occurs at the analysis phase of the intelligence cycle (Katter, Montgomery and Thompson 1979). Analysis can focus on anywhere from current to long term situations, and often

draws on the expertise of multiple specialist analysts to develop multidimensional comprehension of a particular situation (JP 2-0, 2007). Analysts are commonly expected to apply their knowledge in the subject area to anticipate the implications of a situation's current status, and its likely future state, for decision-makers' goals and objectives (USG 2009). Analysts decide and act across analysis, production, evaluation and dissemination.

6.4. Intelligence cycle phase 8 (*Production*) is analogous to the *Decision* and *Action* components of SA theory.

The process of creating a coherent piece of finished intelligence explaining the analyst's findings, rationale, limitations, recommendations, etc., is referred to as "production;" the finished intelligence, which can be in any media format, is often referred to as an "intelligence product" (e.g. President's Daily Brief or National Intelligence Estimates; ODNI 2011). Thus, the analyst must make decisions that amount to findings (i.e. decision-making in the context analysis) as well as decisions about product design (i.e. decision-making in the context of intelligence production) that culminate in the creation of an intelligence product (i.e. action in the context of intelligence production) intended to meet the stated needs of the consumer. Production can involve reiterations of decision and action.

6.5. Intelligence cycle phase 9 (*Evaluation*) is analogous to the *Decision* and *Action* components of SA theory.

The analyst, and under some circumstances the analyst's superior, must also carry out an evaluation of the intelligence product, to verify that it fulfills the consumer/decision-maker's stated intelligence requirements, prior to the product's dissemination (ICD 203, 2007). Evaluation can involve reiterations of decision and action when products are evaluated negatively (JP 2-0, 2007; ICD 203, 2007). In such cases, judgment (decision) is made to reject (action) the product and this cycle is repeated until the product is evaluated to be satisfactory. Conversely, if the product is evaluated positively, judgment is made to clear the product for dissemination.

6.6. Intelligence cycle phase 10 (*Dissemination*) is analogous to the *Action* component of SA theory.

The action of disseminating a useful and appropriate intelligence product is the ultimate functional objective of the intelligence analyst (Treverton and Gabbard 2008). Intelligence products may be disseminated physically, electronically, presented formally or simply communicated, depending on the type of intelligence involved, consumer needs and specifications, and temporal, locational, or other practical considerations (e.g. National Security briefings provided by ODNI Staff to the President or the President's National Security Advisors; ODNI 2011).

6.7. Intelligence cycle phase 11 (*Consumption*) is analogous to the Level 1 SA (*Perception*), Level 2 SA (*Comprehension*), and Level 3 SA (*Projection*) components of SA theory.

The disseminated product is consumed (listened to, read, or otherwise perceived) by the decision-maker (ODNI 2011). Consumption initiates the process of SA synthesis in the mind of the consumer. Consumed intelligence is not always passively assimilated; the decision-maker often compares the product's contents to information held in memory to develop personal understanding of the situation (Lowenthal 2000, 123). While perception and lower level comprehension may occur in rapid succession, higher level comprehension of the situation and the internal formation of projections by the decision-maker may require a period of reflection and rumination.

6.8. Intelligence cycle phase 12 (*Feedback*) is analogous to the *Action* component of SA theory.

In the context of the intelligence cycle, feedback refers to the decision-maker's confirmation or denial, to an Intelligence Community liaison, that the intelligence product has met his or her stated information requirements regarding the situation of interest (ODNI, 2011). It is an action by the decision-maker that is inherent to the cycle itself.

Though integral to the USNSIE, issuing feedback is not, of course, the decision-maker's definitive function. The role of the decision-maker is to make decisions that lead to action on, or in reaction to, a situation of interest, as necessary in light of strategic goals and objectives. If the incoming intelligence suggests that a situation requires action, then the decision-maker will make a decision concerning what action is required and, to some extent, how it should be carried out. In many cases, the decision-maker in government does not carry out an action but rather directs one or more proxy actors to do so (Johnson 2012, 79; Lowenthal 2000, 107).

Alternatively, if intelligence suggests that the situation is already conducive to the goals and objectives of the decision-maker, action may not be required. Yet another possibility is that the intelligence presents the situation differently than the decision-maker had previously conceived of it, and the decision-maker must revise his or her goals and objectives to accommodate this new understanding (Lowenthal 2000, 2-3). If action affecting the relative state of the situation is carried out by the decision-maker or proxy, the situation changes and a new enterprise SA development and synthesis process must be undertaken by the US Intelligence Community and the decision-maker to establish current awareness of it.

7. DISCUSSION

Our case study findings demonstrate that the USNSIE can be explained using SA theory. In adapting Endsley's theoretical model to describe the functionality of the USNSIE, we first developed a preliminary model (Figure 3) to describe how organizational SA-support system might work. Through comparison of our findings from the case study with this preliminary model, we were able to modify it and produce a verified accurate description of what the USNSIE does, in the form of the USNSIE process model that incorporates the intelligence cycle (Figure 4). The USNSIE model provides us with both 1) a process description of the USNSIE that accounts for SA-formation, decision-making and action by the decision-maker; and which associates key actor types in the US IC with their functions across intelligence cycle phases, and 2) a generic template describing how a team effort can be incorporated to support the SA of decision-makers. In other words, beyond merely providing a description of the USNSIE that can facilitate further research into the USNSIE as an SA phenomenon, the USNSIE process model also offers a template that can be applied toward the design of a situation aware ISRM (SA-IRSM) process. Our adaptation of the USNSIE model for use in ISRM is offered in Figure 5.

The primary goal of the SA-IRSM process is to support the situation awareness of the decision-maker (in this case the information security risk manager). The driving activities within the SA-IRSM model are routinized collection and analysis activities. Throughout the course of this ongoing investigative process, new risks are identified and old risks are retired to suit the current status of the organization's own information security environment. Analysis and reporting functions highlight where the organization's risk assessment has changed since last performed, as well as projections about the future where there are indications of a shifting threat landscape. The net result is optimized information security situation awareness within the implementing organization.

The SA-IRSM process addresses the first deficiency we identified in our literature review by requiring the identification of specific intelligence requirements (to include risk intelligence on intangible assets, asset interdependencies, human factors, trends, known countermeasures, etc.) so that planning for the collection of the target data and its subsequent analysis can take place. For example, identifying risks related to intangible knowledge assets requires new human and technical resources (e.g. outside consultants with business process management expertise, internal personnel responsible for core business processes that have intangible knowledge assets, software for collection and analysis of data) to be procured so that the right data can be collected, analyzed and reported in support of the bigger picture risk assessment.

This collection-analysis cycle describes an investigative process that aims to collect the maximum amount of relevant information rather than the minimum amount, redressing the second deficiency we identified in our literature review. As a result, the organization is able to identify risks more accurately and to reduce reliance on blind estimation/speculation. In addition to comprehensive collection treatments for specific types of risk intelligence (such as intangible asset intelligence, mentioned above), the scope of the collection mission itself is holistic. During the first stage of the risk assessment phase, i.e. 'risk identification,' the SA-IRSM process involves the direction of collection activities across the organization (e.g. by incident response teams in regard to past incidents, by policy personnel in regard to past violations of policy, training personnel in regard to observed instances and patterns of human behavior that increase or decrease risk).

Similarly, the other phases of ISRM, communication and consultation with stakeholders, context establishment, risk treatment, monitoring, and record-keeping, all benefit from the SA-IRSM process. Communication between stakeholders is informed by evidence reported in current and long term intelligence products during each formalized intelligence priorities establishment phase. Internal intelligence (from within the organization) and external intelligence (e.g. from scholarly, industry, and mainstream media publications) is aggregated and analyzed by management for context establishment. Risk treatment decisions are evidence-based. Distributed and specialized collection and analysis activities lead to more accurate monitoring. Lastly, as the SA-IRSM process describes a continuous process of investigation through which considerable "longitudinal" intelligence about the security history of the organization (collected from incident records and previously documented ISRM decisions) can be organized for review prior to ISRM decision-making, the SA-IRSM process is inherently conducive to good record-keeping, redressing the third practical deficiency identified in literature.

In summary, an intelligence-driven ISRM process adhering to the SA-IRSM model must involve the following activities:

1. Specific intelligence requirements are developed to guide ISRM data collection and analysis.
2. Planning for data collection and analysis is formalized and stipulates who will be involved in the collection or reportage of what target data when and how often; who will be responsible for pre-processing or fully analyzing this data when and how often; what communication channels will be used to report/share information; how intelligence products should be structured; how risk intelligence is to be recorded; establishment and enforcement of analytic standards, etc.
3. Direction of ISRM collection and analysis efforts is coordinated and otherwise centrally-managed by the ISRM head.

4. Collection is carried out in accordance with requirements, planning and direction. The ISRM head is responsible for coordinating and resolving conflicting collection efforts where necessary.
5. Processing is carried out automatically (where possible) and in accordance with planning and direction.
6. Exploitation is carried out automatically (where possible) and in accordance with planning and direction.
7. Analysis may be computer assisted but is principally carried out by a human analyst. Analysis adheres to strict analytical standards and is otherwise carried out in accordance with requirements, planning and direction. Where multiple analysts are involved in a particular project, the ISRM head takes steps to fuse their analyses.
8. Production may be computer assisted but is principally carried out by a human analyst. ISRM intelligence products adhere to strict production standards and meet issued intelligence requirements, highlighting any intelligence gaps or potentially controversial findings.
9. Evaluation occurs prior to dissemination to ensure that ISRM intelligence products meet issued requirements and adhere to production standards.
10. Dissemination to consumers takes place across predetermined communication channels; dissemination into depositories or databases is carried out in accordance with pre-established guidelines.
11. Consumption must occur or the intelligence enterprise is futile; it may serve the organization's interest to hold consumers accountable for decision-making and action that is incongruous with supplied intelligence findings.
12. The consumer is obligated to issue feedback as to whether a consumed intelligence product meets the issued requirements, or if standing intelligence requirements must be revised.

8. CONCLUSION

In this paper we present a situation aware information security risk management SA-IRSM process model that can be used to facilitate improved situation awareness in ISRM. In principle, an intelligence-driven process provides accurate, relevant, and complete information in a timely manner to enable quality decision-making.

The SA-IRSM model makes a contribution to ISRM theory and practice by addressing three critical deficiencies reported in literature. An ISRM method that incorporates the SA-IRSM model will involve the systematic collection and analysis of security risk information prior to decision-making. The model is suitable for highly competitive organizations in which information security is understood to be synonymous with business process security, having direct implications for the functionality of the organization and its fulfillment of strategic objectives. The proposed ISRM process obliges organizations to consider all sources of risk to information security during a comprehensive risk identification phase that culminates in the issuance of prioritized intelligence requirements wherever information is currently lacking (redressing deficiency 1). The SA-IRSM process then incorporates feedback loops to direct the intelligence entity's further investigation of security risks, leading to (more accurate) evidence-based risk estimation (redressing deficiency 2). Finally, the SA-IRSM process is intended to reference all relevant security risk related intelligence (including historic intelligence) continuously as opposed to intermittently (redressing deficiency 3). This capability implies that the ISRM team should become aware of short-term and long-term trends that may influence the organization's security situation.

8.1 Challenges to Practice

However, any intelligence-driven process can fail in numerous ways. Decision-makers can be vague about their requirements, the collection process can be unsystematic or not comprehensive, and critical information can be inaccessible because of the unwillingness of information owners to share or participate in the process (Wheaton 2009). Specifically, organizations face a range of practical challenges in implementing the SA-IRSM model. First, a key issue will be resourcing the various activities, including the collection of the large volume of security information required, its analysis, and the reporting and dissemination of findings to the various stakeholders. The expense involved will likely make the SA-IRSM model relevant only to those organizations willing to commit substantial resources on an ongoing basis for optimal protection. Further, it may not be possible to maintain ongoing situation awareness for all known information security risks but rather only a select number of previously identified high-priority security risks (e.g. those related to an organization's core business processes or their competitive advantage or to a unique high-value asset).

Second, given the large volume of information security intelligence that can be generated from the physical and digital environments, and the relatively slow and laborious process of analysis, a key issue will be producing actionable intelligence (e.g. to incident response teams) in a timely manner. Third, producing "fused" intelligence that has been analyzed based on all sources of available intelligence from across the enterprise will be challenging. Fourth, acquiring intelligence from the necessary stakeholders may be hard, as it will require profound trust relationships between them and the information security personnel who will be handling (and analyzing) the sensitive information. Fifth, the reliability of finished intelligence depends not only on the quality of raw and processed intelligence provided to the analyst, but also on his or her personal competence. Finally, ISRM decision-makers may make decisions *despite* intelligence rather than because of it. Ultimately, assessment of the information security situation is up to decision-makers, who are certainly not bound to follow the advice prepared for them by subordinate analysts.

8.2 Challenges to theory

The SA-IRSM model is the first stage of our work towards determining *how situation awareness can be improved in information security risk management*. Our intention is to adapt the SA-IRSM process model offered in Figure 4 to describe ISRM-supportive intelligence activities at different levels of an organization. To do this, we will have to identify membership for an ISRM team and determine how collection and analysis responsibilities should be distributed. Taking Coles and Moulton's (2003) recommendation that ISRM activities should be driven largely by business process owners, we are considering an arrangement in which business process owners would have tasking authority over collection and analysis personnel located within an organization's various departments, in much the same way that National Intelligence Managers have tasking authority over Intelligence Community elements in the USNSIE.

A significant limitation of our study is that it is yet unclear whether an ISRM process based on the USNSIE is feasible. The USNSIE has a vast budget and pool of expertise at its disposal, and the role of these factors may be greater than we realize.

8.3 Future work

The next stage of our research will be to focus on the connection between our SA model developed for ISRM and the ISRM process. Whereas the SA-IRSM model describes a high-level *process*, explaining how this process supports ISRM must be articulated in terms of a *method*. The next stage of this project will be to combine the SA-IRSM model with provisions of a best practice ISRM

method (e.g. ISO/IEC 27005). We will then integrate recommendations from ISRM literature with findings from our case study of the USNSIE to propose actor and function types within the method.

These proposed elements for the method will be refined and validated using input from subject matter experts, which we will elicit via focus groups and interviews. We will first conduct interviews with subject matter experts from the ISRM field. These interviews will elicit expert advice concerning the general feasibility of the overall method we propose as well as general, high level recommendations concerning the membership of the ISRM team and what functions these members should perform. Following incorporation of this input, we will then present the resulting method to a focus group. While the purpose of the initial expert interviews will be to determine what elements of the proposed method are considered valid propositions in the broad sense, the purpose of the focus groups will be to revise, refine, and validate lower level elements of the formerly validated method.

To empirically refine and validate the SA-ISRM model, an action research approach will be used to develop and refine specific process interventions that can be applied to ISRM practice in multiple organizations. These interventions will take the form of new processes and procedures that guide organizations through the process of SA/intelligence requirements identification, as well as through specific collection and analysis procedures.

9. REFERENCES

- Abidi, Bisma R., Nash R. Aragam, Yao Yi, and Mongi A. Abidi. 2008. "Survey and Analysis of Multimodal Sensor Planning and Integration for Wide Area Surveillance." *ACM Computing Surveys* 41, no. 1: 1-36.
- Ahmad, Atif, Justin Hadgkiss, and A.B. Ruighaver. 2012. "Incident response teams – Challenges in supporting the organizational security function." *Computers & Security* 31, 643-652.
- AS/NZS ISO/IEC 27005:2011 (2011). Information technology - Security techniques - Information security risk management (ISO/IEC 27005:2011, MOD)
- Baskerville, R. 1991. "Risk Analysis: an interpretive feasibility tool in justifying information systems security." *European Journal of Information Systems* 1, no.2: 121-130.
- Bedny, Gregory, and David Meister. 1999. "Theory of Activity and Situation Awareness." *International Journal of Cognitive Ergonomics* 3, no. 1: 63.
- Bolstad, C. 2001. "Situation Awareness: Does It Change With Age?" In Proceedings of the Human Factors and Ergonomics Society 45th Annual Meeting, 272-276. Santa Monica, CA: Human Factors and Ergonomics Society.
- Bruno, Greg and Sharon Otterman. 2008. "National Intelligence Estimates." Council on Foreign Relations website. Available at: <http://www.cfr.org/iraq/national-intelligence-estimates/p7758>
- Carley, Kathleen. 1993. "Coding Choices for Textual Analysis: a Comparison of Content Analysis and Map Analysis." *Sociological Methodology* 23, no. 1: 75-126
- Chauvin, C., Lardjane, S., Morel, G., Clostermann, J. P., & Langard, B. (2013). Human and organizational factors in maritime accidents: Analysis of collisions at sea using the HFACS. *Accident Analysis & Prevention*, 59, 26-37.
- Coles, Robert S., and Rolf Moulton. 2003. "Operationalizing IT risk management." *Computers & Security* 22.6: 487-493.
- Colwill, Carl. 2009. "Human factors in information security: The insider threat – Who can you trust these days?" *Information Security Technical Report* 14, no. 4: 186-196.

- DeFraités, Robert F., and William C. Chambers. 2007. "Gaining Experience with Military Medical Situational Awareness and Geographic Information Systems in a Simulated Influenza Epidemic." *Military Medicine* 172, no. 10: 1071-1076.
- Dinev, T., and Q. Hu. 2007. "The Centrality of Awareness in the Formation of User Behavioral Intention toward Protective Information Technologies." *Journal of the Association for Information Systems* 8, no. 7: 386-408.
- Dube, T.E., R.A. Raines, M.R. Grimaila, K.W. Bauer, and S.K. Rogers. 2013. "Malware Target Recognition of Unknown Threats." *IEEE Systems Journal* 7, no. 3: 467-477.
- Endsley, M.R. 1988. "Design and Evaluation for Situation Awareness Enhancement." *Proceedings of the Human Factors Society 32nd Annual Meeting*, 97-101. Santa Monica, California: Human Factors Society.
- Endsley, M.R. 1990. "A Methodology for the Objective Measurement of Situation Awareness." *Situational Awareness in Aerospace Operations*. AGARD-CP-478, 1/1-1/9. Neuilly Sur Seine, France: NATO-AGARD.
- Endsley, M.R. 1995. "Toward a Theory of Situation Awareness in Dynamic Systems." *Human Factors* 37, no. 1: 32-64.
- Endsley, Mica R., Garland, D. J., Wampler R. L., and Michael D. Matthews. 2000a. *Modeling and Measuring Situation Awareness in the Infantry Operational Environment*. U.S. Army Research Institute for the Behavioral and Social Sciences. Virginia.
- Endsley, M.R., D.J. Garland, R.W.C. Shook, J. Coello, and M. Bandiero. 2000b. "Situation Awareness Problems in General Aviation." SATech 00-01. Marietta, GA: SA Technologies, Inc.
- Endsley, Mica R. and Debra G. Jones. 2011. *Designing for Situation Awareness: an Approach to User-Centered Design*. Boca Raton, Florida; London: CRC Press.
- Espinosa, J.A., S.A. Slaughter, R.E. Kraut, and J.D. Herbsleb. 2007. "Team knowledge and coordination in geographically distributed software development." *Journal of Management Information Systems* 24, no. 1: 135-169.
- Fioratou, E., R. Flin, R. Glavin, and R. Patey. 2010. "Beyond Monitoring: Distributed Situation Awareness in Anaesthesia." *BJA: The British Journal of Anaesthesia* 105, no. 1: 83-90.
- Groner, Norman, Charles Jennings, and Amy Robinson. 2012. "A Negotiated-Text Method for Assessing Situation Awareness Information Requirements from Emergency Responders." *2012 IEEE International Multi-Disciplinary Conference on Cognitive Methods in Situation Awareness & Decision Support*, 259.
- Gryszkiewicz, Anna, and Fang Chen. 2012. "Temporal aspects in crisis management and its implications on interface design for situation awareness." *Cognition, Technology & Work* 14, no. 2: 169-182.
- Harris, Shon. 2010. *CISSP All-in-One Exam Guide*. New York. McGraw-Hill.
- Harvey, C, NA Stanton, CA Pickering, M McDonald, and P Zheng. 2011. "To twist or poke? A method for identifying usability issues with the rotary controller and touch screen for control of in-vehicle information systems." *Ergonomics* 54, no. 7: 609-625.
- Hogg, D.N., B. Torralba, and F.S. Volden. 1993. *A Situation Awareness Methodology for the Evaluation of Process Control Systems: Studies of Feasibility and the Implication of Use*. 1993-03-05. Storefjell, Norway: OECD Halden Reactor Project.

- Hulme, G. V. "Getting at Risk." In *Management of Information Security*, by M. E. Whitman and H. J. Mattord, 307-308. Boston: Thomson Course Technology, 2004.
- ICD 203, 2007. Director of National Intelligence. *Intelligence Community Directive Number 203: Analytic Standards*. Washington, D.C.: Office of the Director of National Intelligence, 2007.
- ICD 300, 2006. Director of National Intelligence. *Intelligence Community Directive Number 300: Management, Integration, and Oversight of Intelligence Collection and Covert Action*. Washington, D.C.: Office of the Director of National Intelligence, 2006.
- ICD 900, 2006. Director of National Intelligence. *Intelligence Community Directive Number 900: Mission Management*. Washington: Office of the Director of National Intelligence, 2006.
- Johnson, Loch K. 2012. *National Security Intelligence: Secret Operations in Defense of the Democracies*. Cambridge, UK; Malden, MA.
- JP 2-0, 2007. Joint Chiefs of Staff. *Joint Publication 2-0: Joint Intelligence*. Washington, D.C.: Office of the Joint Chiefs of Staff, 2007.
- Katter, Robert V., Christine A. Montgomery, and John R. Thompson. 1979. "Human Processes in Intelligence Analysis." *Research Report 1237*. US Army Research Institute for the Behavioral and Social Sciences, US Army Intelligence and Security Command.
- Koch, SH, C Weir, M Haar, N Staggers, J Agutter, M Görges, and D Westenskow. 2012. "Intensive care unit nurses' information needs and recommendations for integrated displays to improve nurses' situation awareness." *Journal of The American Medical Informatics Association* 19, no. 4: 583-590.
- Kotulic, A. G. and J. G. Clark (2004). "Why There Aren't More Information Security Research Studies." *Information and Management*. 41: 597-607.
- Kowalski, Eileen, Dawn Cappelli, and Andrew Moore. United States Secret Service National Threat Assessment Center and CERT Program, Carnegie Mellon University Software Engineering Institute. 2008. *Insider Threat Study: Illicit Cyber Activity in the Information Technology and Telecommunications Sector*. Washington, D.C., Pittsburgh, PA.
- Lowenthal, Mark M. 2000. *Intelligence: From Secrets to Policy*. Washington, D.C.: CQ Press.
- Matwyshyn, Andrea. 2009. "CSR and the Corporate Cyborg: Ethical Corporate Information Security Practices." *Journal of Business Ethics* 88, 579-594.
- Miller, J.O. 2004. "Modeling the US Military Intelligence Process." Department of Operational Sciences, Air Force Institute of Technology. Wright Patterson, OH.
- Morineau, T, X Morandi, N Le Moellic, S Diabira, L Riffaud, C Haegelen, PL Henaux, and P Jannin. 2009 "Decision Making During Preoperative Surgical Planning." *Human Factors* 51, no. 1: 67-77.
- Naweed, A, GRJ Hockey, and SD Clarke. 2013. "Designing Simulator Tools for Rail Research: The Case Study of a Train Driving Microworld." *Applied Ergonomics* 44, no. 3: 445-454.
- Neuman, William Lawrence. 2011. *Social Research Methods: Qualitative and Quantitative approaches*. Boston, Massachusetts: Allyn & Bacon.
- Ng, Boon-Yuen, and Atreyi Kankanhalli. 2012. "Information Systems for Large-Scale Event Management: A Case Study." *Pacific Asia Journal of The Association For Information Systems* 4, no. 3: 1.
- ODNI - Office of the Director of National Intelligence. 2011. *US National Intelligence: an Overview*. Intelligence Consumer's Guide. Washington, DC.

- Oh, O., M. Agrawal, and H.R. Rao. 2011. "Information control and terrorism: Tracking the Mumbai terrorist attack through twitter." *Information Systems Frontiers* 13, no. 1: 33-43.
- Parker, Donn B. 2007. "Risks of Risk-Based Security." *Communications Of The ACM* 50, no. 3: 120.
- Pennathur, P.R., D.P. Cao, A.M. Bisantz, L. Lin, R.J. Fairbanks, R.L. Wears, S.J. Perry, T.K. Guarrera, J.L. Brown, and Z. Sui. 2011. "Emergency department patient-tracking system evaluation." *International Journal Of Industrial Ergonomics* 41, no. 4: 360-369
- Raiu, Costin. 2012. "Cyber-Threat Evolution: the Past Year." *Computer Fraud & Security* 3, 5-8.
- Rees, J, and J Allen. 2008. "The State of Risk Assessment Practices in Information Security: An Exploratory Investigation." *Journal of Organizational Computing and Electronic Commerce* 18, no. 4: 255-277.
- Reid, J., R. Hull, B. Clayton, G. Porter, and P. Stenton. 2010. "Priming, sense-making and help: Analysis of player behaviour in an immersive theatrical experience." *Pervasive And Mobile Computing* 6, no. 5: 499-511.
- Riley, J. M., Kaber, D. B., & Draper, J. V. (2004). Situation awareness and attention allocation measures for quantifying telepresence experiences in teleoperation. *Human Factors and Ergonomics in Manufacturing & Service Industries*, 14(1), 51-67.
- Rogstadius, J, M Vukovic, CA Teixeira, V Kostakos, E Karapanos, and JA Laredo. 2013. "CrisisTracker: Crowdsourced social media curation for disaster awareness." *IBM Journal Of Research And Development* 57, no. 5.
- Rousseau, R., S. Tremblay, and R. Breton. 2004. "Defining and Modeling Situation Awareness: A Critical Review." In *A Cognitive Approach to Situation Awareness: Theory and Application*, by S. Tremblay and S. Banbury, eds. Ashgate Publishing Company, Burlington, pp. 3-21.
- Sauer, J, DG Wastell, GRJ Hockey, CM Crawshaw, M Ishak, and JC Downing. 2002. "Effects of display design on performance in a simulated ship navigation environment." *Ergonomics* 45, no. 5: 329-347.
- Schmittling, Ron. 2010. "Performing a Security Risk Assessment." *ISACA Journal*, Vol. 1: 1-7.
- Schnell, Thomas, Yongjin Kwon, Sohel Merchant, and Timothy Etherington. 2004. "Improved Flight Technical Performance in Flight Decks Equipped With Synthetic Vision Information System Displays." *International Journal Of Aviation Psychology* 14, no. 1: 79-102.
- Senior, Annette, and Richard Copley. 2008. "Deploying a new system for recording and managing information during an emergency to aid decision making." *Journal Of Business Continuity & Emergency Planning* 2, no. 3: 267-280.
- Shaw, R.S., C.C. Chen, A.L. Harris, and H.J. Huang. 2009. "The impact of information richness on information security awareness training effectiveness." *Computers & Education* 52, no. 1: 92-100.
- Shedden, Piya, A. B. Ruighaver, and Atif Ahmad. 2010. "Risk Management Standards - The Perception of ease of use." *Journal of Information System Security* 6, no. 3: 23-41.
- Shedden, Piya, Rens Scheepers, Wally Smith, and Atif Ahmad. 2011. "Incorporating a knowledge perspective into security risk assessments." *VINE: The Journal of Information & Knowledge Management Systems* 41, no. 2: 152.
- Sim, I., D. Liginlal, and L. Khansa. 2012. "Information Privacy Situation Awareness: Construct and Validation." *Journal of Computer Information Systems* 53, no. 1: 57-64.
- Siponen, M. 2006. "Information Security Standards Focus on the Existence of Process, not Its Content." *Communications of the ACM* 49, no. 8: 97-100.

- Smith, K. and P.A. Hancock. 1995. "Situation Awareness Is Adaptive, Externally Directed consciousness." *Human Factors* 37, no. 1: 137-148.
- Sonnenwald, Diane H., Kelly L. Maglaughlin, and Mary C. Whitton. 2004. "Designing to support situation awareness across distances: an example from a scientific collaboratory." *Information Processing & Management* 40, no. 6: 989-1011.
- Stewart, Geordie, and David Lacey. 2012. "Death by a thousand facts: Criticising the technocratic approach to information security awareness." *Information Management & Computer Security* 20, no. 1: 29.
- Treverton, Gregory F., Seth G. Jones, Steven Boraz, Philip Lipsky. 2006. "Toward a Theory of Intelligence." RAND National Security Research Division Workshop Report (Conference Proceedings).
- Treverton, Gregory F., and C. Bryan Gabbard. 2008. "Assessing the Tradecraft of Intelligence Analysis." RAND National Security Research Division Technical Report.
- USG - US Government. 2009. *A Tradecraft Primer: Structured Analytic Techniques for Improving Intelligence Analysis*. Washington, D.C.: US Central Intelligence Agency, Center for the Study of Intelligence.
- Utin, Daniil M., Mikhail A. Utin, and Jane Utin. 2008. "General Misconceptions about Information Security Lead to an Insecure World." *Information Security Journal: A Global Perspective* 17, no. 4: 164-169.
- Wheaton, Kristan J. (2009): Evaluating Intelligence: Answering Questions Asked and Not, *International Journal of Intelligence and Counter Intelligence*, 22:4, 614-631
- Whitman, Michael E., and Herbert J. Mattord. 2004. *Management of information security*. Boston, Mass. Thomson Course Technology.
- Yin, R. K. 2009. *Case Study Research: Design and Methods*. Thousand Oaks, California: SAGE.
- Yang, Lili, Su Guofeng, and Yuan Hongyong. 2012. "Design Principles of Integrated Information Platform for Emergency Responses: The Case of 2008 Beijing Olympic Games." *Information Systems Research* 23, no. 3: 761-786

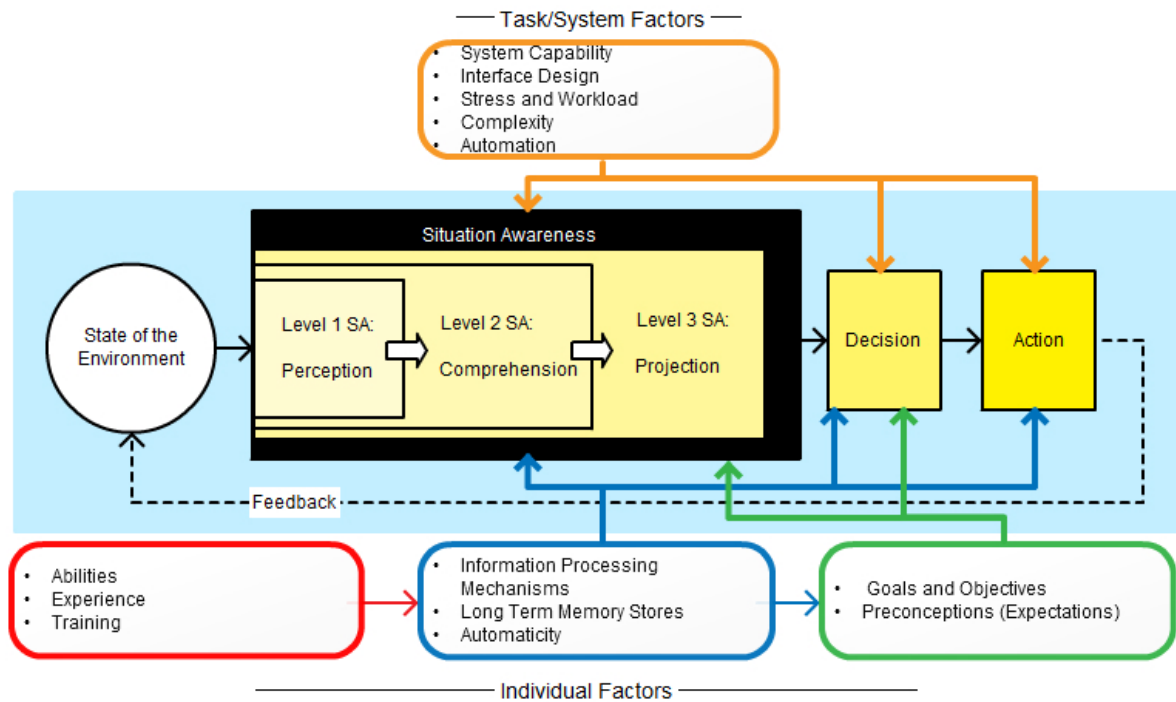


Figure 1: Endsley's SA Model (Adapted from Endsley 1995)

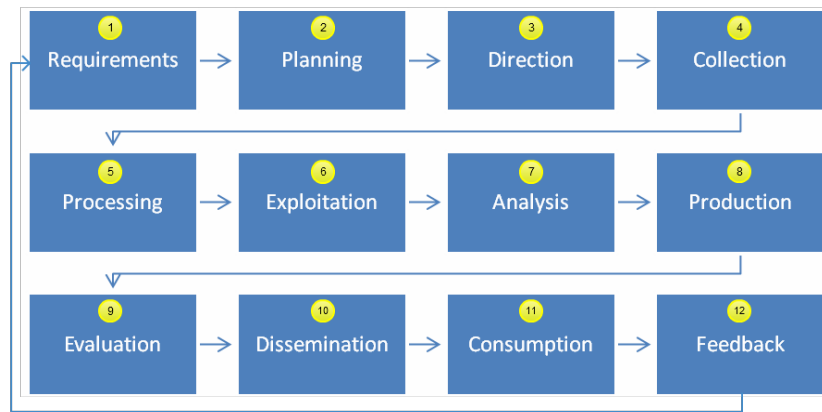


Figure 2: The Intelligence Cycle in 12 phases

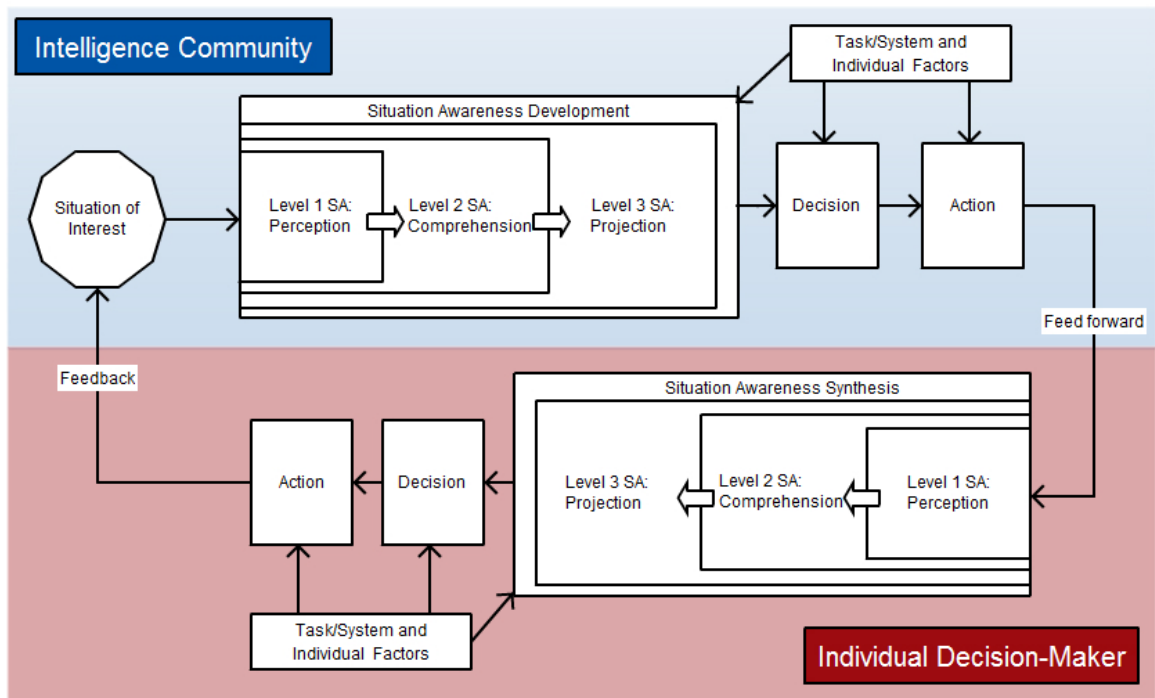


Figure 3: Our Initial Adaptation of Endsley's Model to Describe the USNSIE

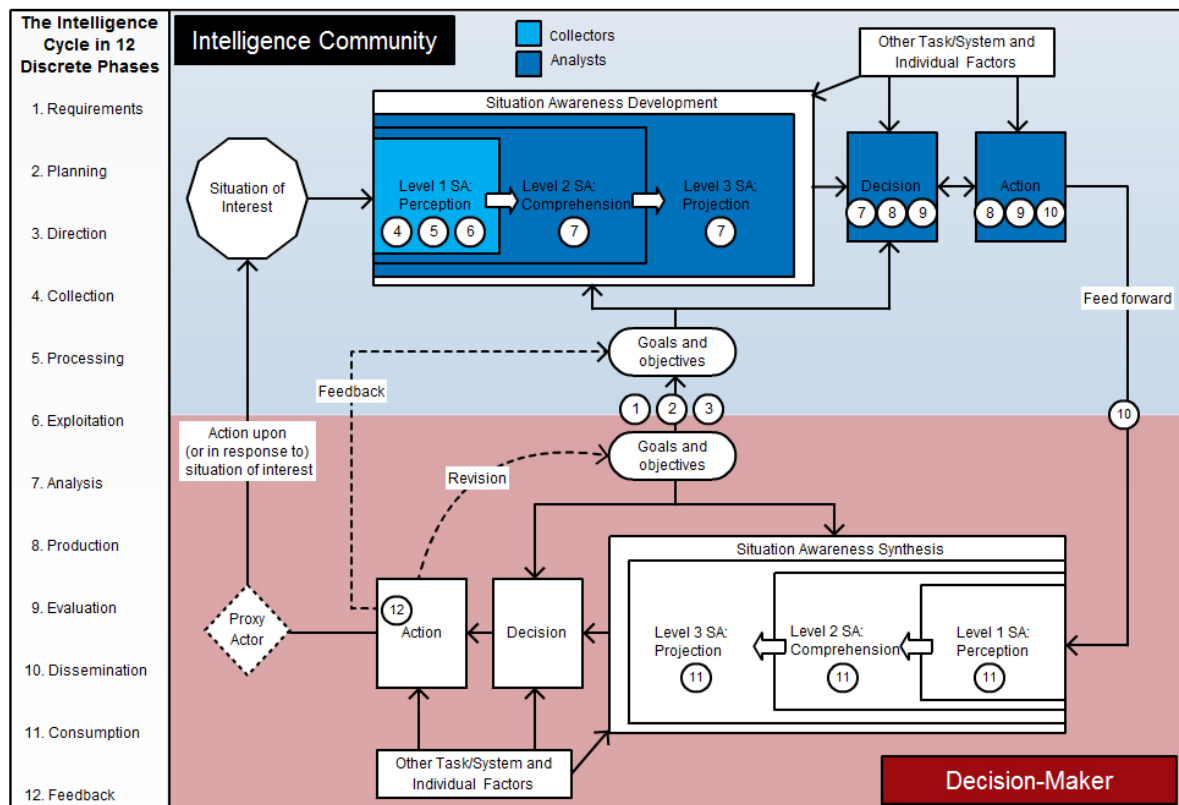


Figure 4: The USNSIE Model

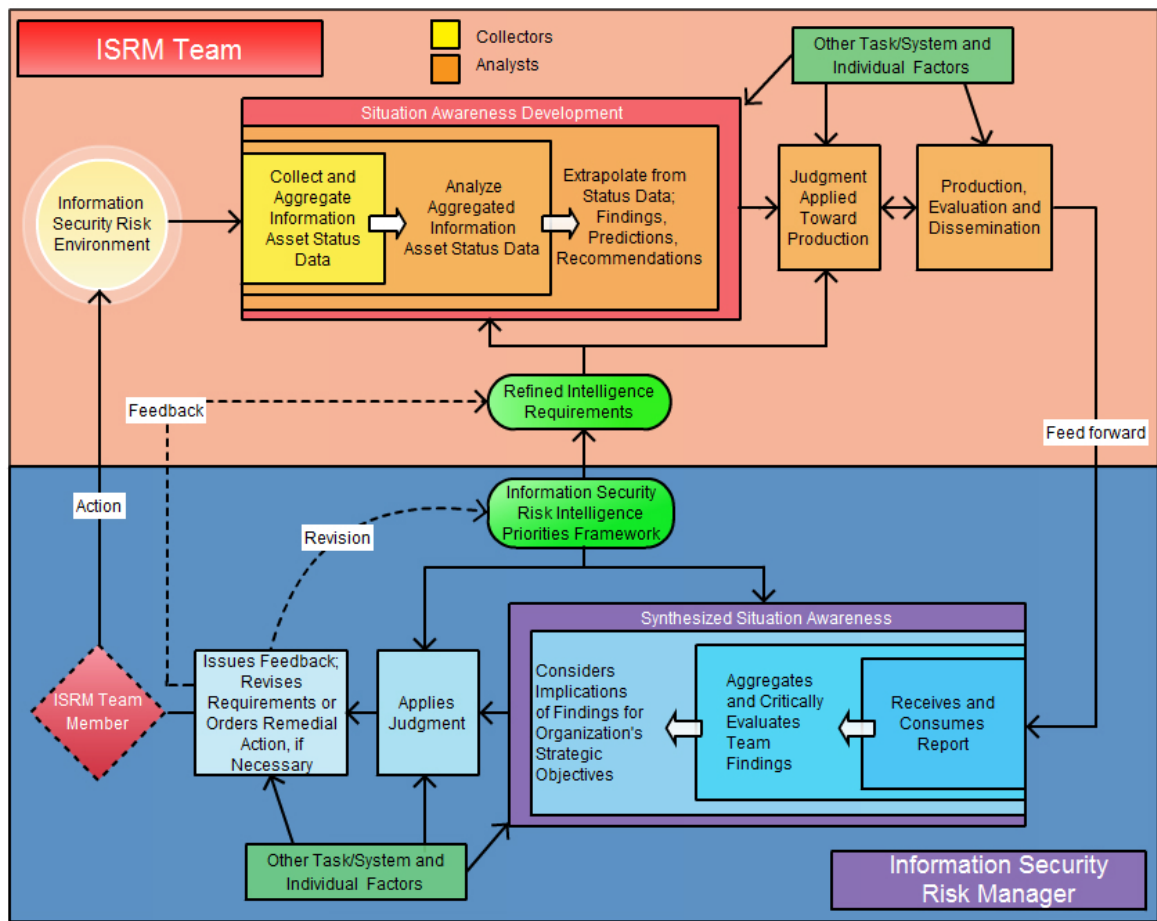


Figure 5: The SA Model for Use in ISRM (SA-ISRM)